

M204:

Assurer le durcissement des systèmes et des réseaux informatiques

Partie 1 : PRÉSENTER LES NORMES ET LES STANDARDS DE DURCISSEMENT

Principes clés du durcissement :

Durcissement : Le durcissement consiste à réduire la surface d'attaque pour rendre les systèmes moins vulnérables aux cyberattaques.

Zero trust : Un principe repose sur l'idée que "Seulement les utilisateurs légitimes qui ont seulement les bons accès seulement aux justes données pour seulement la bonne raison"

Sécurité en profondeur : Une stratégie de cybersécurité où plusieurs couches de mécanismes défensifs sont superposées pour retarder et détecter les attaques.

Moindres privilèges : Réduire les accès et la complexité des systèmes pour limiter les risques.

Le principe des 3D :

- **Deter (Dissuader)** : Rendre les attaques plus difficiles.
- **Deny (Bloquer)** : Bloquer les attaques avant qu'elles ne se produisent.
- **Delay (Retarder)** : Retarder les attaques pour gagner du temps pour une réaction.

•Chapitre1 : Identifier les normes et référentiels de durcissement

1. Normes ANSSI

- ❖ **ANSSI** : (Agence nationale de la sécurité des systèmes d'information) Autorité nationale chargée de la sécurité des systèmes d'information de l'État français et de la contribution à la sécurité des opérateurs nationaux d'importance vitale (OIV).
- ❖ **Normes ANSSI** :
 - Recommandations de configuration d'un système GNU/Linux
 - Recommandations relatives à l'administration sécurisée des systèmes d'information
 - Sécuriser un site web
 - Recommandations de sécurité relatives à Active Directory

2. Référentiel CIS

- ❖ **CIS** : Le Center for Internet Security (CIS) est une organisation à but non lucratif qui développe des frameworks de sécurité pour protéger les systèmes et les données contre les cybermenaces.
- ❖ **CIS Benchmark** : Les CIS Benchmarks sont des guides de configuration sécurisée, détaillant des recommandations techniques pour durcir des systèmes, applications et infrastructures contre les cybermenaces.
- ❖ **CIS Benchmark : les catégories**
 - **Systèmes d'exploitation (Windows, Linux, macOS)** : Paramètres de sécurité de base pour les OS.
 - **Cloud & Virtualisation (AWS, Azure, VMware)** : Bonnes pratiques pour sécuriser les environnements cloud.

- **Logiciels serveurs (SQL, Exchange, Docker)** : Configurations renforcées pour les serveurs et bases de données.
- **Logiciels bureautiques (Office, navigateurs, PDF)** : Sécurisation des applications critiques.
- **Appareils mobiles (iOS, Android)** : Protection des smartphones et tablettes en entreprise.
- **Réseaux (Pare-feu, routeurs, VPN)** : Durcissement des équipements réseau.
- **Périphériques (Imprimantes, scanners)** : Sécurité des appareils connectés

❖ **CIS Benchmark : les niveaux**

- **Niveau 1** : Recommandations de sécurité de base pour une configuration facile et à faible impact.
- **Niveau 2** : Sécurité renforcée pour des données sensibles, nécessitant une expertise professionnelle.
- **STIG** : Recommandations de configuration pour les systèmes de défense spécifiés par le ministère de la Défense des États-Unis.

•Chapitre 2: Connaître les bonnes pratiques de l'administration sécurisée

1. SI d'administration (bastion)

- ❖ **Un bastion d'administration** est une ressource essentielle qui renforce la protection des comptes administrateurs. Il garantit que seuls les bons utilisateurs accèdent aux bonnes ressources avec les bons droits.
- **Solutions de bastion** : (Ex : **One Identity, Wallix, CyberArk**) offrent des fonctionnalités telles que l'authentification multifacteur, la gestion des accès, et l'intégration avec des outils SIEM pour la gestion des alertes et des tickets.

2. Outils d'administration (local/centralisé)

- ❖ **Un outil d'administration local** est installé sur un poste d'administration local et permet à l'administrateur de contrôler des ressources sur place.
Ex : AD Manager Plus, AD Pro Toolkit, phpMyAdmin.
- ❖ **Un outil d'administration à distance ou centralisé** est déployé sur des serveurs dédiés et offre un contrôle à distance sur des ressources multiples.
Ex : Dameware Remote Support, Atera, ISL Online.

3. Automatisation des règles de durcissement (Lynis, PingCastle, CIS-CAT)

- ❖ **Lynis, PingCastle et CIS-CAT** : sont des outils utilisés pour automatiser les vérifications de sécurité et la remédiation des écarts. Ils offrent des rapports détaillés et des recommandations pour améliorer la sécurité des systèmes.
- **Lynis** (open source) effectue des audits de sécurité des systèmes Linux.
- **PingCastle** (programme autonome) analyse la configuration d'Active Directory.
- **CIS-CAT** (version Pro payante et version Lite gratuite) compare la configuration des systèmes aux benchmarks de sécurité du CIS.

Partie 2 : MAITRISER LE DURCISSEMENT DU RÉSEAU

•Chapitre1 : Identifier les composants basiques d'un réseau informatique

1. Pare-feux

❖ **Un pare-feu** est un logiciel ou un matériel qui surveille et filtre le trafic réseau en fonction d'un ensemble de règles prédéfinies.

❖ Types de pare-feu :

- **Pare-feu matériel** : Ce sont des appareils physiques dédiés qui filtrent le trafic réseau.
- **Pare-feu logiciel** : Des programmes installés sur des systèmes d'exploitation pour filtrer le trafic entrant et sortant d'un réseau.
- **Pare-feu personnel** : Destiné à protéger un seul système ou un petit réseau, comme ceux que l'on trouve dans les routeurs domestiques.
- **Pare-feu commercial** : Utilisé pour protéger de plus grands réseaux, avec des performances et une fiabilité accrues.

❖ Types de filtrage :

- **Pare-feu à filtrage de paquets** : Inspecte uniquement les en-têtes des paquets (adresses IP, ports) sans suivre l'état des connexions.
- **Passerelle au niveau du circuit** : Contrôle la prise de contact TCP (handshake) pour valider les connexions selon les règles du pare-feu.
- **Pare-feu d'inspection avec état** : Suit l'état des connexions TCP et bloque les paquets qui ne font pas partie d'une session établie.
- **Pare-feu proxy (ou WAF - Web Application Firewall)** : Agit comme un intermédiaire entre le client et le serveur. Il analyse en profondeur le contenu des paquets pour protéger notamment les applications Web.
- **Cloud Firewall ou Firewall as a Service (FWaaS)** : Pare-feu déployé dans le cloud, offrant une protection évolutive et flexible sans avoir besoin de matériel physique.
- **Pare-feu de nouvelle génération (NGFW)** : Combine les fonctionnalités classiques de pare-feu avec des capacités avancées comme l'analyse des applications, la détection d'intrusions en temps réel et la décryption du trafic SSL/TLS.
- **UTM (Unified Threat Management)** : Les solutions UTM intègrent plusieurs fonctionnalités de sécurité (pare-feu, antivirus, antispam, VPN, etc.) dans une plateforme unique, simplifiant la gestion et renforçant l'efficacité de la sécurité réseau.

2. VPN (OpenVPN, Wireguard et IPSEC)

❖ **VPN (Virtual Private Network)** est une technologie qui permet de créer un tunnel sécurisé entre des appareils situés sur des réseaux différents, offrant ainsi une communication privée et sécurisée sur des réseaux publics ou non fiables.

❖ Avantages des VPN :

- Connexion sécurisée entre réseaux géographiquement séparés
- Confidentialité des échanges de données
- Anonymat de la navigation en masquant l'adresse IP réelle

❖ Technologies VPN :

- **PPP (Point-to-Point Protocol)** : Utilisé par certains VPN comme PPTP pour authentifier les utilisateurs et chiffrer les données. Fonctionne avec un système de clé privée et certificat public (similaire au fonctionnement de SSH).

- **PPTP (Point-to-Point Tunneling Protocol)** : Permet aux données PPP de voyager via un tunnel sur Internet. Ancienne technologie, aujourd'hui considérée peu sécurisée.
- **IPSec (Internet Protocol Security)** : Protocole qui chiffre directement les paquets IP. Il est complexe à configurer mais offre un chiffrement fort et est largement supporté sur de nombreux appareils et systèmes.
- **OpenVPN** : Logiciel open source qui permet de créer un tunnel VPN hautement sécurisé. Réputé pour sa flexibilité, compatibilité et robustesse en matière de sécurité.
- **WireGuard** : Protocole VPN de nouvelle génération. Simple à configurer, très rapide et plus léger que OpenVPN et IPSec, avec un code source plus court, ce qui facilite l'audit de sécurité.

• Chapitre 2 : Appliquer les configurations de sécurité sur les composants d'un réseau informatique

1. Durcissement des protocoles réseaux (NBT-NS, LLMNR, WPAD, TLS)

❖ NBT-NS / LLMNR :

Link-Local Multicast Name Resolution (LLMNR) et **Netbios Name Service (NBT-NS)** sont deux protocoles utilisés dans les réseaux Microsoft pour résoudre les noms d'hôtes quand DNS échoue.

Vulnérabilité :

Risque d'attaque par "poisoning" où un attaquant répond aux requêtes pour capter des identifiants (ex : hash NTLM).

Durcissement :

- Désactiver LLMNR et NBT-NS
- Mise en place du NAC (Network Access Control).
- Exiger des mots de passe robustes (>14 caractères, éviter les mots courants).

❖ WRAD :

Le protocole **WPAD (Web Proxy Auto-Discovery Protocol)** permet aux navigateurs de trouver automatiquement la configuration d'un proxy.

Vulnérabilité :

Peut être détourné pour rediriger le trafic réseau vers un serveur malveillant.

Durcissement :

- Désactiver LLMNR/NBT-NS.
- Désactiver la détection automatique des paramètres proxy.
- Ajouter une entrée "wpad" dans le fichier hosts pour le faire pointer vers 127.0.0.1.

❖ TLS :

TLS (Transport Layer Security) est un protocole cryptographique qui sécurise les communications réseau via un chiffrement symétrique.

Processus TLS :

- Le serveur envoie son certificat SSL au client.
- Le client vérifie la validité du certificat, puis envoie un numéro aléatoire chiffré avec la clé publique du serveur.
- Le serveur utilise ce numéro pour générer la clé de session.
- La clé de session est transmise de façon chiffrée, souvent via Diffie-Hellman.
- La communication sécurisée peut commencer.

Vulnérabilités :

- Heartbleed Bug (OpenSSL, corrigé en 2014)
- Faiblesses historiques liées à l'exportation de la cryptographie.
- Attaques via compression HTTP, BEAST, Padding Oracle, etc.

Durcissement :

- Choisir des algorithmes et versions sécurisées (préférer TLS 1.3).
- Désactiver les versions obsolètes et les suites cryptographiques faibles.

2. Durcissement d'un Firewall

✓Durcir et configurer correctement le pare-feu

- Utiliser un système d'exploitation renforcé et mis à jour.
- Suivre les guides de bonnes pratiques (CIS Benchmarks...).
- Appliquer une configuration sécurisée dès l'installation.

✓Planifier le déploiement de votre pare-feu

- Adapter le pare-feu selon l'architecture réseau (L3 routé ou L2 en pont).
- Appliquer les principes Zero Trust.
- Définir les segments réseau (externe, interne, DMZ, Wi-Fi invité...).

✓Sécuriser le pare-feu

- Désactiver les protocoles non sécurisés (Telnet, SNMP...).
- Activer l'audit des modifications et transmettre les journaux à un SIEM sécurisé.
- Ajouter une règle furtive pour masquer le pare-feu.
- Limiter l'accès de gestion.
- Appliquer correctifs contre les vulnérabilités connues.

✓Comptes utilisateurs sécurisés

- Modifier les comptes par défaut, appliquer une politique de mot de passe fort, activer le MFA.
- Utiliser le RBAC pour limiter les droits (lecture seule, accès restreint selon les rôles).

✓S'assurer que la politique et l'utilisation du pare-feu soient conformes aux normes

- Vérifier la conformité du pare-feu avec les réglementations (RGPD, ISO 27001...).
- Intégrer des outils complémentaires : VPN, antivirus, IDS/IPS.

✓Tester pour vérifier la politique et identifier les risques

- Analyser la stratégie avec des outils d'analyse de chemin.
- Réorganiser les règles pour optimiser les performances.
- Réaliser des tests d'intrusion réguliers.

✓Logiciel d'audit ou micrologiciel et journaux

- Mettre en place un plan formel de gestion des changements.
- Mettre à jour logiciels/firmwares.
- Éviter les règles "Tout autoriser", les restreindre au besoin.
- Organiser les règles en sections hiérarchiques avec commentaires explicites.
- Activer et consulter les journaux d'audit régulièrement.

Partie 3 : MAITRISER LE DURCISSEMENT DU SYSTÈME

•Chapitre1 : Identifier des systèmes d'exploitation

1. Système Windows (serveurs et poste de travail)

Les versions de Windows poste de travail : XP, Vista, 7, 8.x, 10 , 11 .

Les versions de Windows serveur : Windows NT, 2003, 2008, 2012, 2016, 2019, 2022.

2. Systèmes Linux

Les avantages de Linux :

- Gratuit et open-source.
- Modifiable par toute personne ayant des compétences en programmation.
- Riche en logiciels
- Sécurité en constante amélioration.
- Idéal pour les serveurs : stabilité, fiabilité, et capacité à fonctionner des années sans redémarrage (utilisé par Amazon, Google, etc.).

•Chapitre 2 : Appliquer les configurations de sécurité sur les OS

1. Durcissement Windows

❖ Durcissement Windows

Le durcissement d'un système d'exploitation Windows consiste à appliquer un ensemble de configurations pour réduire sa vulnérabilité face aux attaques. Avant toute configuration, il faut connaître l'objectif :

- Prévenir les attaques connues.
- Réduire la surface d'attaque.
- Protéger les données sensibles.
- Automatiser les processus de sécurité.
- Standardiser les configurations.

❖ Outils et techniques de durcissement

1. Windows Defender Application Control (WDAC)

- Contrôle des applications autorisées à s'exécuter.
- Utilise UEFI pour stocker les politiques.
- Signature numérique obligatoire des politiques via PKI.

2. Virtualization Based Security (VBS)

- Isole les zones critiques en mémoire.
- Active Secure Boot, protection DMA, et démarrage sécurisé (DRTM).

3. Credential Guard

- Utilise VBS pour isoler et protéger les identifiants (NTLM, Kerberos).
- Empêche les attaques de type "Pass-the-Hash".
- La configuration Enabled with UEFI lock ajoute une couche de sécurité en stockant les paramètres dans l'UEFI.

❖ les fonctionnalités à désactiver pour réduire les risques

- **Windows Telemetry** : collecte de données par Microsoft.
- **PowerShell** : désactiver la version 2.0 et restreindre l'exécution de scripts.
- **Windows Script Host (WSH)** : peut être utilisé pour lancer des malwares via des scripts.

❖ Durcissement d'Active Directory (AD)

- **Principe du moindre privilège** : Limiter l'usage de comptes à privilèges pour les tâches quotidiennes sur : AD, serveurs, postes de travail, applications.
- **Hôtes d'administration sécurisés** : Utiliser des machines dédiées à l'administration avec :
 - ✓ Accès par carte à puce.
 - ✓ Sécurité physique.
 - ✓ AppLocker.
 - ✓ Restrictions RDP.
 - ✓ Gestion des mises à jour (WSUS ou Endpoint Manager).
 - ✓ Blocage d'accès à Internet
- **Sécurisation des contrôleurs de domaine** :
 - ✓ Gérer les groupes de sécurité Active Directory.

- ✓ Nettoyer les comptes d'utilisateurs inactifs dans AD.
- ✓ Surveiller les administrateurs locaux.
- ✓ Auditer les connexions au contrôleur de domaine (DC).
- ✓ Assurer la protection LSASS.
- ✓ Une politique de mot de passe stricte.
- ✓ Backup et restaure de l'Active Directory .

2. Durcissement Linux

❖ La sécurité dans Linux

Linux, en tant que système d'exploitation multi-utilisateur, intègre nativement des mécanismes de sécurité robustes :

- bonne séparation des privilèges entre comptes administrateurs et utilisateurs simples.
- Il est moins ciblé par les virus que Windows.
- Il inclut des systèmes de sécurité comme SELinux (Red Hat, CentOS) et AppArmor (Ubuntu).
- Son code open source permet de repérer les failles plus rapidement.

❖ Durcissement Linux

- **Garder le noyau Linux et les logiciels à jour**

Appliquer les mises à jour de sécurité dès qu'elles sont disponibles avec apt, yum, etc.

- **Supprimer les logiciels inutiles**

Vérifier et désinstaller les paquets non essentiels pour limiter les vulnérabilités .

- **Sécurisation des comptes utilisateurs**

Appliquer le principe du moindre privilège et Éviter l'utilisation du compte root directement.

- **Renforcer le contrôle d'accès noyau (SELinux):**

SELinux (Security-Enhanced Linux) implémente un contrôle d'accès obligatoire (MAC) dans le noyau Linux.

Modes disponibles :

- ✓ Enforcing : applique les politiques.
- ✓ Permissive : enregistre mais ne bloque pas.
- ✓ Disabled : inactif.

- **Configuration d'AppArmor**

AppArmor permet de restreindre les permissions d'un programme via des profils.

- **Partitions de disque séparées**

Isoler certains répertoires critiques dans des partitions séparées permet de limiter les dégâts: /usr, /var, /var/tmp, /tmp, /home

- **Utiliser un outil comme Lynis**

Lynis est un outil d'audit de sécurité pour systèmes Linux. Il évalue les faiblesses de configuration et propose des recommandations..

Partie 4 : DÉPLOYER DES SOLUTIONS DLP ET DE TRAÇABILITÉ

•Chapitre1 : Configurer une solution DLP

1. Définition de la notion DLP

❖ DLP

DLP (Data Loss Prevention) est une stratégie conçue pour réduire les risques liés aux fuites ou pertes de données critiques. Elle protège les informations critiques contre les accès non autorisés, les erreurs humaines ou les attaques.

Le logiciel DLP :

- Surveille, détecte et empêche la fuite des données sensibles.
- Analyse les données entrantes et sortantes sur le réseau.
- Peut bloquer certains comportements, comme :
 - L'envoi d'e-mails en dehors du domaine
 - Le téléchargement vers des plateformes cloud non autorisées (ex : Dropbox).
 - L'utilisation de clés USB pour copier des fichiers sensibles.

❖ Les technologies DLP

DLP dédiés : sont des produits autonomes approfondis et complexes.

DLP intégrés : plus simples, intégrés à d'autres outils de sécurité, moins coûteux.

Solutions populaires :

- **Symantec DLP (Broadcom)** – Cloud, endpoints, data centers.
- **Checkpoint Data Loss** – Exfiltration et violations de données.
- **CoSoSys Endpoint Protector** – DLP tout-en-un (Windows, macOS, Linux).
- **ManageEngine Device Control Plus** – Sécurité des périphériques USB.
- **McAfee Total Protection DLP** – Suite complète pour surveillance et prévention.
- **SolarWinds DLP avec Access Rights Manager** – Malgré une faille passée, toujours performant.
- **VikingCloud Endpoint Protection** – Cible les risques internes.

❖ La mise en place d'un programme DLP

- **Inventaire & évaluation** : identifier toutes les données (avec des outils comme Barracuda, Cisco, McAfee).
- **Classification** : distinguer les données personnelles (PII), financières, réglementées, IP...

- **Politiques de gestion** : définir comment traiter chaque type de données.
- **Programme centralisé** : éviter les plans DLP dispersés ; viser une vision unifiée.
- **Formation des employés** : sensibiliser aux risques et aux bonnes pratiques.

❖ Zscaler DLP

Zscaler est une solution cloud de prévention des fuites de données qui protège les informations sensibles lorsqu'elles quittent l'entreprise (navigation web, e-mails, cloud). Elle détecte, bloque ou surveille les tentatives de fuite selon des règles définies, même pour les utilisateurs à distance.

• Chapitre 2 : Configurer une solution de gestion de la traçabilité

1. Définition de la traçabilité

❖ La traçabilité

La traçabilité permet d'identifier l'origine et de reconstituer le parcours d'un élément (donnée, attaque, action, accès, etc.) à travers un système d'information.

- **Outils et protocoles de traçabilité** : Syslog / SNMPv3 / Windows Event

❖ la journalisation et la surveillance des événements

- **Journalisation (logging)** : enregistrement des erreurs et événements.
- **Surveillance (monitoring)** : collecte et analyse des métriques pour comprendre le comportement du système.

Un bon système de traçabilité permet d'identifier :

1. **Reconnaissance** : les attaquants observent votre environnement.
2. **Armement** : ils préparent une attaque.
3. **Livraison** : ils exploitent une vulnérabilité.
4. **Installation** : un logiciel malveillant est introduit.
5. **Commande & contrôle** : les attaquants prennent la main.
6. **Action** : comprendre leurs objectifs et bloquer leurs mouvements.

2. Configuration des politiques de traçabilité

- ❖ **Syslog** : un protocole utilisé pour collecter et enregistrer les messages ou événements système sur les serveurs et équipements réseau (Linux, routeurs, etc.).
- ❖ **CloudTrail** : un service AWS qui enregistre toutes les actions effectuées sur ton compte cloud (création de ressources, connexions, modifications, etc.), pour auditer et tracer les activités.